

Challenge Name: mal medium - 100 (Threat Intel L1)

The image shows a 'Challenge Info' window with a dark theme. On the left, there's a graphic with the text 'mal medium 100' and a blue button labeled 'Description'. To the right of the button, it says '182 Solves'. On the right side of the window, under the heading 'Description', it asks 'Can you trace the infection path and identify the C2 domain?' and lists the source as 'mal_medium.zip'. At the bottom right, it shows '1/3 attempts'. At the very bottom of the window, there is a 'Flag' input field and a blue button with a speech bubble icon.

Approach

The challenge asks you to trace an infection path and identify a C2 (command-and-control) domain. Network logs (DNS, HTTP, etc.) commonly show hosts contacted by an infected host. Look for unusual hostnames, especially ones containing suspicious tokens (e.g., **malicious**, **ops**, **secpen**, unusual TLDs), outliers in IPs, or repeated/different responses that suggest an active C2.

What I observed

I opened `network.log` in a text editor and searched for suspicious keywords like **mal**, **c2**, **cmd**, **infect**, or obvious domain substrings.

A relevant excerpt found by searching for **mal**:

The image is a screenshot of a text editor window with multiple tabs. The active tab is 'network', which displays a list of DNS queries. A search bar at the top right of the editor shows the search term 'mal'. One line in the log is highlighted in blue: '[DNS] Query malicious-ops.secpen.net -> 185.223.142.130'. Other visible entries include queries to 'ocsp.verisign.net', 'cdn.cloudflare.com', and 'telemetry.microsoft.com'.

Among these DNS queries, `malicious-ops.secpen.net` stands out as a clearly suspicious domain (contains `malicious` and `ops`), unlike the expected infrastructure domains (`ocsp.verisign.net`, `cdn.cloudflare.com`, `windowsupdate.com`).

Why this is likely the C2

- The domain name contains obvious malicious indicator words (`malicious-ops`), which is highly suspicious for network traffic seen from an infected host.
- It appears alongside legitimate (benign) DNS queries, suggesting the infected host is attempting to contact its C2 among normal traffic.
- C2 domains frequently use operational-sounding subdomains (e.g., `ops`) to masquerade as legitimate infrastructure; the presence of `malicious` removes the disguise and signals intentionality in the challenge.
- The challenge explicitly asks for the C2 domain — this domain is the clear candidate.

Tools / quick commands used

If you need to reproduce this locally or automate searching logs:

```
# basic grep for suspicious tokens
grep -i 'mal\|c2\|cmd\|ops\|infect' network.log

# search for unique domain strings (shows context)
grep -Eo '([a-z0-9\.-]+\.[a-z]{2,})' network.log | sort | uniq -c | sort -rn

# look for DNS queries specifically
grep '\[DNS\] Query' network.log | sed -E 's/.*Query ([^ ]+) .*/\1/' | sort | uniq -c
```

Final

The identified C2 domain is:

Flag: `SPL{malicious-ops.secpen.net}`

~By: 1nfln1ty